

Confirmation Flow Specification

Some tool calls have significant side effects or require human approval. When the permission policy for a tool is set to `require_confirmation`, the execution is paused and must be resumed only after explicit confirmation. This document defines the confirmation flow in detail.

Flow Overview

1. **Triggering condition:** The workflow orchestrator encounters a tool call where the permission engine returns `require_confirmation` for at least one of its permission scopes.
2. **Pause execution:** The orchestrator stops processing subsequent steps. The step status is set to `pending`, and the execution status becomes `pending_confirmation`.
3. **Return pending response:** The API returns a response indicating that confirmation is required. It includes the `execution_id`, the tool ID, the permission scope requiring confirmation, and any relevant context (e.g. a summary of the input). See example below.
4. **Notify user:** The calling application (`ragenius_app`) should notify the appropriate user or administrator that confirmation is needed. The notification may include a link to a confirmation endpoint and details of the pending operation.
5. **Confirmation request:** The user (or automated process) calls the confirmation endpoint (e.g. `POST /v1/executions/:execution_id/confirm`) with a decision (`approved` or `rejected`) and an optional comment. The request should be authenticated and authorized.
6. **Resume or fail:**
7. If approved: The orchestrator resumes the workflow from the paused step and proceeds as normal. Execution status changes back to `running`.
8. If rejected: The orchestrator sets the execution status to `failed` with a `permission` error and ends the workflow.
9. **Expiration:** If no confirmation is provided within a configured period (e.g. 15 minutes), the execution automatically fails with a timeout or permission error.
10. **Audit:** All confirmation requests, decisions and timestamps must be logged for auditing.

Pending Confirmation Response Example

When a step triggers confirmation, the API returns a 202 response like this:

```
{
  "execution_id": "exec_042",
  "status": "pending_confirmation",
  "result_type": "json",
  "result": {
```

```

    "required_confirmation": true,
    "tool_id": "filesystem.delete",
    "permission_scope": "filesystem.delete",
    "input_summary": {
      "path": "/tmp/important.txt"
    }
  },
  "files": [],
  "errors": [],
  "logs_summary": "Tool call requires confirmation before execution."
}

```

Confirmation Endpoint

Endpoint: POST /v1/executions/:execution_id/confirm

Request Body:

```

{
  "decision": "approved",      // or "rejected"
  "comment": "optional notes",
  "actor_id": "user_123"      // ID of the user who is confirming
}

```

Responses:

Status	Description
200 OK	Confirmation accepted. The response includes the updated execution status (<code>running</code> or <code>failed</code>) and a summary of the next action.
400 Bad Request	Invalid decision value or malformed request.
403 Forbidden	The caller lacks permission to confirm this execution.
404 Not Found	Execution not found or not in a pending state.

The confirmation endpoint must validate that:

1. The execution exists and is in `pending_confirmation` status.
2. The caller is authorized to confirm this execution (based on scopes or roles).
3. The decision is either `approved` or `rejected`.
4. The confirmation period has not expired.

Notification Guidelines

- Include key context so users understand what they are approving: the tool being called, the target (e.g. file name, external entity), the input summary (redacted if necessary), and the potential impact.
- Provide links to the execution detail and logs so users can review the workflow history before confirming.
- Timebox the decision and state what happens on expiration.
- Allow users to add comments when approving or rejecting; comments should be stored with the execution.
- Record the identity of the actor confirming for auditing.

Expiration Policy

- Define a default expiration period (e.g. 15 minutes) in configuration.
- At expiration, automatically reject the pending tool call and mark the execution as failed.
- Log the expiration event.
- Optionally allow clients to specify a custom timeout per execution if allowed by policy.

Security Notes

- Confirmation endpoints must require authentication and appropriate authorization.
 - Rate limit confirmation attempts to prevent brute force.
 - Do not accept anonymous confirmations.
 - Use CSRF protection for web-based confirmations.
 - Do not include full payloads or secrets in the pending confirmation response; only a summary.
-